

# INFRASTRUCTURE VULNERABILITY ASSESSMENT



## Disclaimer

All information contained in this document is confidential and proprietary to **Vsion Networks** and **XYZ Pvt Ltd**. Reproduction, disclosure, or use of any information contained in this document by photographic, electronic or any other means, in whole or part, for any reason other than for the purpose of operations and/or security enhancement of **XYZ Pvt Ltd** through internal review is strictly prohibited without written consent.

The use of the information / test results **XYZ Pvt Ltd** name responsibility and depends on the Vsion Networks ability to evaluate and integrate it into **XYZ Pvt Ltd** name operational environment. While each item may have been reviewed by **Vsion Networks** for accuracy in a specific situation, there is no guarantee that the same or similar results will be obtained elsewhere.

Neither **Vsion Networks** nor any of its employees makes any warranty, expressed or implied, or assumes any legal liability or responsibility for the completeness or usefulness of any information, report or process disclosed herein or represents that its use will not infringe privately owned rights.

## Limitations on Disclosure and Use

This document contains sensitive and confidential information concerning vulnerabilities of **XYZ Pvt Ltd** name target infrastructure. **Vsion Networks** recommends that special precautions be taken to protect the confidentiality of the information contained in this report.

While **Vsion Networks** is confident that the major security vulnerabilities of the target Infrastructure have been identified, there can be no assurance that an assessment of this nature will identify all possible security exposures. Additionally, the findings and recommendations presented in this document are based on the technologies and known threats as of the date of this report. As technologies and risks change over time, the vulnerabilities and the recommendations associated with the Client Name target infrastructure may also change.

## Contents

|                                                                                        |                              |
|----------------------------------------------------------------------------------------|------------------------------|
| <b>Executive Summary</b>                                                               | <b>6</b>                     |
| <b>Assessment Types &amp; Scope</b>                                                    | <b>7</b>                     |
| <b>Vulnerabilities Table</b>                                                           | <b>20</b>                    |
| <b>1. Microsoft SQL Server Unsupported Version Detection</b>                           | <b>22</b>                    |
| <b>2. Apache Tomcat vulnerable version in use</b>                                      | <b>24</b>                    |
| <b>3. SSL Version 2 and 3 Protocol Detection</b>                                       | Error! Bookmark not defined. |
| <b>4. Microsoft Message Queuing RCE (QueueJumper)</b>                                  | <b>26</b>                    |
| <b>5. SSL 64-bit Block Size Cipher Suites Supported (SWEET32)</b>                      | <b>28</b>                    |
| <b>6. Microsoft ASP.NET MS-DOS Device Name DoS</b>                                     | <b>31</b>                    |
| <b>7. Multiple BSD ipfw / ip6fw ECE Bit Filtering Evasion</b>                          | Error! Bookmark not defined. |
| <b>8. Remote Desktop Protocol Server Man-in-the-Middle weakness</b>                    | Error! Bookmark not defined. |
| <b>9. SSL Certificate cannot Be Trusted</b>                                            | <b>34</b>                    |
| <b>10. SSL Self-Signed Certificate</b>                                                 | <b>37</b>                    |
| <b>11. TLS Version 1.0 Protocol Detection</b>                                          | <b>40</b>                    |
| <b>12. TLS Version 1.1 Deprecated Protocol</b>                                         | <b>43</b>                    |
| <b>13. JQuery 1.2 &lt; 3.5.0 Multiple XSS</b>                                          | Error! Bookmark not defined. |
| <b>14. SSL RC4 Cipher Suites Supported (Bar Mitzvah)</b>                               | <b>46</b>                    |
| <b>15. Microsoft Windows IIS Default Index Page</b>                                    | Error! Bookmark not defined. |
| <b>16. SSL Certificate Signed Using Weak Hashing Algorithm</b>                         | Error! Bookmark not defined. |
| <b>17. SSL Certificate with Wrong Hostname</b>                                         | Error! Bookmark not defined. |
| <b>18. SMB Signing Not Required</b>                                                    | Error! Bookmark not defined. |
| <b>19. Web Server HTTP Header Information Disclosure</b>                               | Error! Bookmark not defined. |
| <b>20. Terminal Services Does Not Enforce Network Level Authentication (NLA) Only</b>  | Error! Bookmark not defined. |
| <b>21. SSL/TLS Diffie-Hellman Modulus &lt;= 1024 Bits (Logjam)</b>                     | Error! Bookmark not defined. |
| <b>22. SSLv3 Padding Oracle on Downgraded Legacy Encryption Vulnerability (POODLE)</b> | Error! Bookmark not defined. |
| <b>23. Terminal Services Encryption Level Is Not FIPS-140 Compliant</b>                | Error! Bookmark not defined. |
| <b>Attacks and Exploits Performed</b>                                                  | <b>48</b>                    |
| <b>Appendix A – Vulnerability Severity Rating</b>                                      | <b>51</b>                    |

PROJECT OVERVIEW

Activity  NETWORK VULNERABILITY ASSESSMENT

Prepared by: Varun Sulakhe R

Reviewed by: Vinoth Kumar V

Start Date: 15-08-2025

End Date: 23-08-2025

Test Location: [Onsite]

# INFRASTRUCTURE VULNERABILITY ASSESSMENT

5

**Scope of Work: Total 15 IPs.**

| Sl. No | IP's       | Vulnerable /non-vulnerable |
|--------|------------|----------------------------|
| 1.     | X.X.80.2   | Vulnerable                 |
| 2.     | X.X.80.3   | Vulnerable                 |
| 3.     | X.X.80.4   | Vulnerable                 |
| 4.     | X.X.80.5   | Vulnerable                 |
| 5.     | X.X.80.6   | Vulnerable                 |
| 6.     | X.X.80.7   | Vulnerable                 |
| 7.     | X.X.80.8   | Vulnerable                 |
| 8.     | X.X.80.15  | Vulnerable                 |
| 9.     | X.X.80.20  | Vulnerable                 |
| 10.    | X.X.80.35  | Vulnerable                 |
| 11.    | X.X.80.36  | Vulnerable                 |
| 12.    | X.X.80.165 | Vulnerable                 |
| 13.    | X.X.80.168 | Vulnerable                 |
| 14.    | X.X.80.214 | Vulnerable                 |
| 15.    | X.X.81.12  | Vulnerable                 |

## Executive Summary

**Vsion Networks** conducted the infrastructure vulnerability assessment of **XYZ Pvt Ltd** accessible over the internet to identify Infrastructure vulnerability assessment from internal environment. The Penetration Testing was performed from 31<sup>th</sup> Mar 2025 to 8<sup>th</sup> Apr 2025.

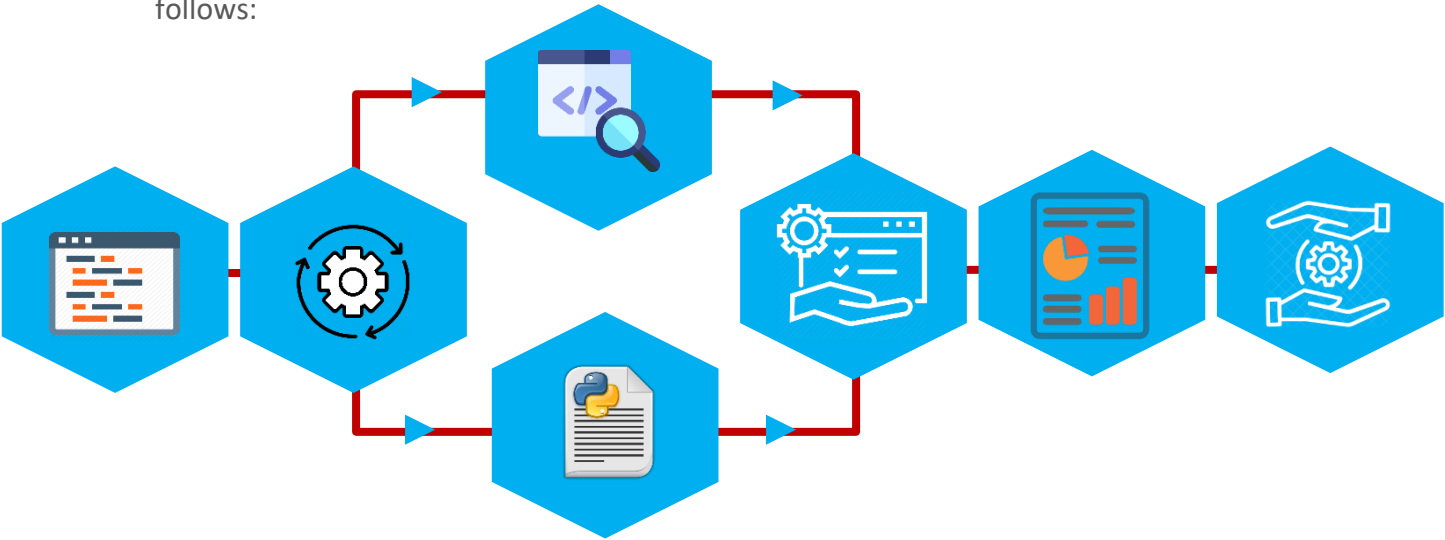
Infrastructure vulnerability assessment was limited to the scope mentioned in the Statement of Work agreed between **Vsion Networks** and **XYZ Pvt Ltd**.

### Objective

The objective of this exercise was to assess the **XYZ Pvt Ltd** infrastructure against unauthorized attacks and detect vulnerabilities that may pose a threat to its systems and the application. The report also aims at providing recommendations and guidelines against such threats, which help in protecting the confidentiality and integrity of its systems and the application. The testing process included the use of automated tools as well as manual tests.

### Approach

The testing methodology is a hybrid policy based on OWASP top 10 standards and is as follows:



|                                                                                                                                                |                                                                                                                |                                                                                                                         |                                                                                                                              |                                                                           |                                                                                            |
|------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Application Understanding <ul style="list-style-type: none"><li>• Walkthrough</li><li>• Code Layout</li><li>• Business understanding</li></ul> | Threat Profiling <ul style="list-style-type: none"><li>• Risk Identification</li><li>• Test Planning</li></ul> | Vulnerability Identification <ul style="list-style-type: none"><li>• Automated Scans</li><li>• Manual Testing</li></ul> | Vulnerability Classification <ul style="list-style-type: none"><li>• Detect False Positives</li><li>• Risk rating.</li></ul> | Report <ul style="list-style-type: none"><li>• Technical Report</li></ul> | Support <ul style="list-style-type: none"><li>• Re-assess.</li><li>• Discussions</li></ul> |
|------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|

## Assessment Types & Scope

The type of scan or audit performed determines the nature of the testing conducted on the Web App within the defined scope:

| Scan/Audit Type |             |                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------------|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Level           | Type        | Information                                                                                                                                                                                                                                                                                                                                                                                                     |
| 1               | Standard    | In standard penetration testing, denial of service conditions is avoided. Any disruptive scanning is also avoided to ensure that the application retains its state at the end of the assessment. This is recommended on a live application.                                                                                                                                                                     |
| 2               | Destructive | In a destructive penetration testing, denial of service conditions is exploited. Additionally, any disruptive scanning that may cause application to go down is exploited in a destructive scan. Such a scenario helps to identify the vulnerabilities that may be used by an attacker to trigger a denial-of-service situation. This is least recommended on a live application unless there really is a need. |

The vulnerabilities discovered are associated with a risk level that indicates how critical the vulnerability is and helps application team to prioritize the vulnerabilities and choose an appropriate mitigation approach.

### Assessment Scope

The application security assessment is done on but not limited to the following:

- Fingerprinting
- Active Services
- Vulnerability Exploits
- Risk Assessment
- Application Assessment

### Out of Scope:

- Denial of Service by exhausting system resources
- Social Engineering

### Scan Type:

| Assessment type | Selected |
|-----------------|----------|
| Standard        | Yes      |
| Destructive     | No       |

## Ports Details of Network Devices:

Host: X.X.80.2

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 16:22 +0530
Nmap scan report for SARA-CORP001.SARA.COM (172.16.80.2)
Host is up (0.0032s latency).
Not shown: 65520 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
389/tcp    open  ldap
464/tcp    open  kpasswd5
636/tcp    open  ldapssl
2222/tcp   open  EtherNetIP-1
3389/tcp   open  ms-wbt-server
8403/tcp   open  adminind
9389/tcp   open  adws
10050/tcp  open  zabbix-agent
49667/tcp  open  unknown
49670/tcp  open  unknown
49671/tcp  open  unknown
49673/tcp  open  unknown
49792/tcp  open  unknown
```

Host: X.X.80.3

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 13:10 +0530
Nmap scan report for 172.16.80.3
Host is up (0.019s latency).
Not shown: 65520 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
2222/tcp   open  EtherNetIP-1
5357/tcp   open  wsdaapi
5900/tcp   open  vnc
5985/tcp   open  wsman
8400/tcp   open  cvd
8403/tcp   open  adminind
10050/tcp  open  zabbix-agent
49668/tcp  open  unknown
49745/tcp  open  unknown
50505/tcp  open  unknown
61542/tcp  open  unknown
```



Host: X.X.80.4

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 13:15 +0530
Nmap scan report for 172.16.80.4
Host is up (0.015s latency).
Not shown: 65529 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
5900/tcp   open  vnc
```

Host: X.X.80. 6

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 13:59 +0530
Nmap scan report for SARALSVR.SARA.COM (172.16.80.6)
Host is up (0.0033s latency).
Not shown: 65519 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
1433/tcp   open  ms-sql-s
2222/tcp   open  EtherNetIP-1
5900/tcp   open  vnc
5985/tcp   open  wsman
8400/tcp   open  cvd
8403/tcp   open  admin
8990/tcp   open  http-wmap
9089/tcp   open  sqlexec-ssl
10050/tcp  open  zabbix-agent
49704/tcp  open  unknown
50140/tcp  open  unknown
52574/tcp  open  unknown
```

Host: X.X.80.5

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 13:30 +0530
Nmap scan report for SARA-CORP002.SARA.COM (172.16.80.5)
Host is up (0.0033s latency).
Not shown: 65501 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
2222/tcp   open  EtherNetIP-1
3389/tcp   open  ms-wbt-server
5900/tcp   open  vnc
5985/tcp   open  wsman
6129/tcp   open  unknown
7070/tcp   open  realserver
8088/tcp   open  radan-http
8400/tcp   open  cvd
8403/tcp   open  admind
8501/tcp   open  cmtip-mgt
9000/tcp   open  cslistener
9089/tcp   open  sqlexec-ssl
10000/tcp  open  snet-sensor-mgmt
10001/tcp  open  scp-config
10050/tcp  open  zabbix-agent
19955/tcp  open  unknown
19956/tcp  open  unknown
47001/tcp  open  winrm
49664/tcp  open  unknown
49665/tcp  open  unknown
49668/tcp  open  unknown
49669/tcp  open  unknown
49703/tcp  open  unknown
55574/tcp  open  unknown
55575/tcp  open  unknown
55576/tcp  open  unknown
55588/tcp  open  unknown
55730/tcp  open  unknown
62433/tcp  open  unknown
```

Host: XX.80.7

Starting Nmap 7.97SVN ( <https://nmap.org> ) at 2025-08-12 14:02 +0530

Nmap scan report for SARA-CORP003.SARA.COM (172.16.80.7)

Host is up (0.0027s latency).

Not shown: 65508 filtered tcp ports (no-response)

| PORT      | STATE | SERVICE          |
|-----------|-------|------------------|
| 53/tcp    | open  | domain           |
| 80/tcp    | open  | http             |
| 88/tcp    | open  | kerberos-sec     |
| 135/tcp   | open  | msrpc            |
| 139/tcp   | open  | netbios-ssn      |
| 389/tcp   | open  | ldap             |
| 445/tcp   | open  | microsoft-ds     |
| 464/tcp   | open  | kpasswd5         |
| 593/tcp   | open  | http-rpc-epmap   |
| 636/tcp   | open  | ldapssl          |
| 3268/tcp  | open  | globalcatLDAP    |
| 3269/tcp  | open  | globalcatLDAPssl |
| 3389/tcp  | open  | ms-wbt-server    |
| 5900/tcp  | open  | vnc              |
| 5985/tcp  | open  | wsman            |
| 8530/tcp  | open  | unknown          |
| 8531/tcp  | open  | unknown          |
| 9389/tcp  | open  | adws             |
| 49668/tcp | open  | unknown          |
| 49672/tcp | open  | unknown          |
| 49674/tcp | open  | unknown          |
| 49703/tcp | open  | unknown          |
| 49720/tcp | open  | unknown          |
| 53633/tcp | open  | unknown          |
| 53640/tcp | open  | unknown          |
| 56462/tcp | open  | unknown          |
| 64348/tcp | open  | unknown          |

Host: X.X.80.8

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 12:54 +0530
Nmap scan report for 172.16.80.8
Host is up (0.013s latency).
Not shown: 65514 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
2221/tcp   open  rockwell-csp1
2225/tcp   open  rcip-itv
2229/tcp   open  datalens
3333/tcp   open  dec-notes
3389/tcp   open  ms-wbt-server
5900/tcp   open  vnc
5985/tcp   open  wsman
8098/tcp   open  unknown
8400/tcp   open  cvd
8403/tcp   open  admind
9099/tcp   open  unknown
10050/tcp  open  zabbix-agent
20443/tcp  open  unknown
20445/tcp  open  unknown
49669/tcp  open  unknown
49670/tcp  open  unknown
50306/tcp  open  unknown
50981/tcp  open  unknown
```

Host: X.X.80.15

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 15:13 +0530
Nmap scan report for 172.16.80.15
Host is up (0.0041s latency).
Not shown: 65531 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
```

Host: X.X.80.20

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 15:17 +0530
Nmap scan report for 172.16.80.20
Host is up (0.0035s latency).
Not shown: 65530 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
5900/tcp   open  vnc
```

Host: X.X.80.35

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 15:21 +0530
Nmap scan report for RNWTALLYSVR.SARA.COM (172.16.80.35)
Host is up (0.0037s latency).
Not shown: 65520 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
2222/tcp   open  EtherNetIP-1
3389/tcp   open  ms-wbt-server
5900/tcp   open  vnc
5985/tcp   open  wsman
8400/tcp   open  cvd
8403/tcp   open  admin
10003/tcp  open  documentum_s
10050/tcp  open  zabbix-agent
49680/tcp  open  unknown
49681/tcp  open  unknown
51384/tcp  open  unknown
```

Host: X.X.80.36

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 15:58 +0530
Nmap scan report for RETAILSVR.SARA.COM (172.16.80.36)
Host is up (0.0058s latency).
Not shown: 65526 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
445/tcp    open  microsoft-ds
2222/tcp   open  EtherNetIP-1
5900/tcp   open  vnc
5985/tcp   open  wsman
10050/tcp  open  zabbix-agent
49154/tcp  open  unknown
49156/tcp  open  unknown
```

Host: X.X.80.165

Starting Nmap 7.97SVN ( <https://nmap.org> ) at 2025-08-12 16:01 +0530

Nmap scan report for RUOSH-ANALYTIC.SARA.COM (172.16.80.165)

Host is up (0.0040s latency).

Not shown: 65509 filtered tcp ports (no-response)

| PORT      | STATE | SERVICE      |
|-----------|-------|--------------|
| 21/tcp    | open  | ftp          |
| 25/tcp    | open  | smtp         |
| 80/tcp    | open  | http         |
| 81/tcp    | open  | hosts2-ns    |
| 135/tcp   | open  | msrpc        |
| 139/tcp   | open  | netbios-ssn  |
| 445/tcp   | open  | microsoft-ds |
| 1433/tcp  | open  | ms-sql-s     |
| 1801/tcp  | open  | msmq         |
| 2103/tcp  | open  | zephyr-clt   |
| 2105/tcp  | open  | eklogin      |
| 2107/tcp  | open  | msmq-mgmt    |
| 2222/tcp  | open  | EtherNetIP-1 |
| 5900/tcp  | open  | vnc          |
| 5985/tcp  | open  | wsman        |
| 8400/tcp  | open  | cvd          |
| 8403/tcp  | open  | admind       |
| 9014/tcp  | open  | unknown      |
| 10050/tcp | open  | zabbix-agent |
| 33464/tcp | open  | unknown      |
| 49154/tcp | open  | unknown      |
| 49161/tcp | open  | unknown      |
| 49185/tcp | open  | unknown      |
| 49361/tcp | open  | unknown      |
| 55114/tcp | open  | unknown      |
| 58817/tcp | open  | unknown      |

Host: X.X.80.168

Starting Nmap 7.97SVN ( <https://nmap.org> ) at 2025-08-12 16:07 +0530

Nmap scan report for 172.16.80.168

Host is up (0.0033s latency).

Not shown: 65500 closed tcp ports (reset)

| PORT      | STATE | SERVICE       |
|-----------|-------|---------------|
| 80/tcp    | open  | http          |
| 135/tcp   | open  | msrpc         |
| 139/tcp   | open  | netbios-ssn   |
| 445/tcp   | open  | microsoft-ds  |
| 1234/tcp  | open  | hotline       |
| 1433/tcp  | open  | ms-sql-s      |
| 2222/tcp  | open  | EtherNetIP-1  |
| 2383/tcp  | open  | ms-olap4      |
| 3306/tcp  | open  | mysql         |
| 3389/tcp  | open  | ms-wbt-server |
| 5357/tcp  | open  | wsdapi        |
| 5900/tcp  | open  | vnc           |
| 5985/tcp  | open  | wsman         |
| 8003/tcp  | open  | mcreport      |
| 8004/tcp  | open  | p2pevolvenet  |
| 8005/tcp  | open  | mxi           |
| 8006/tcp  | open  | wpl-analytics |
| 8007/tcp  | open  | ajp12         |
| 8391/tcp  | open  | unknown       |
| 8400/tcp  | open  | cvd           |
| 8403/tcp  | open  | admind        |
| 8717/tcp  | open  | unknown       |
| 10050/tcp | open  | zabbix-agent  |
| 47001/tcp | open  | winrm         |
| 49664/tcp | open  | unknown       |
| 49665/tcp | open  | unknown       |
| 49666/tcp | open  | unknown       |
| 49668/tcp | open  | unknown       |
| 49669/tcp | open  | unknown       |
| 49670/tcp | open  | unknown       |
| 49684/tcp | open  | unknown       |
| 49726/tcp | open  | unknown       |
| 57476/tcp | open  | unknown       |
| 59284/tcp | open  | unknown       |
| 59333/tcp | open  | unknown       |



Host: X.X.80.214

```
└─# nmap -Pn -p- 172.16.80.214
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 12:52 +0530
Nmap scan report for 172.16.80.214
Host is up (0.016s latency).
Not shown: 65507 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
1433/tcp   open  ms-sql-s
1801/tcp   open  msmq
2103/tcp   open  zephyr-clt
2105/tcp   open  eklogin
2107/tcp   open  msmq-mgmt
3306/tcp   open  mysql
5357/tcp   open  wsapi
5800/tcp   open  vnc-http
5900/tcp   open  vnc
5985/tcp   open  wsman
8001/tcp   open  vcom-tunnel
8005/tcp   open  mxi
8006/tcp   open  wpl-analytics
8080/tcp   open  http-proxy
8834/tcp   open  nessus-xmlrpc
47001/tcp  open  winrm
49664/tcp  open  unknown
49665/tcp  open  unknown
49666/tcp  open  unknown
49667/tcp  open  unknown
49669/tcp  open  unknown
49670/tcp  open  unknown
49686/tcp  open  unknown
49697/tcp  open  unknown
```

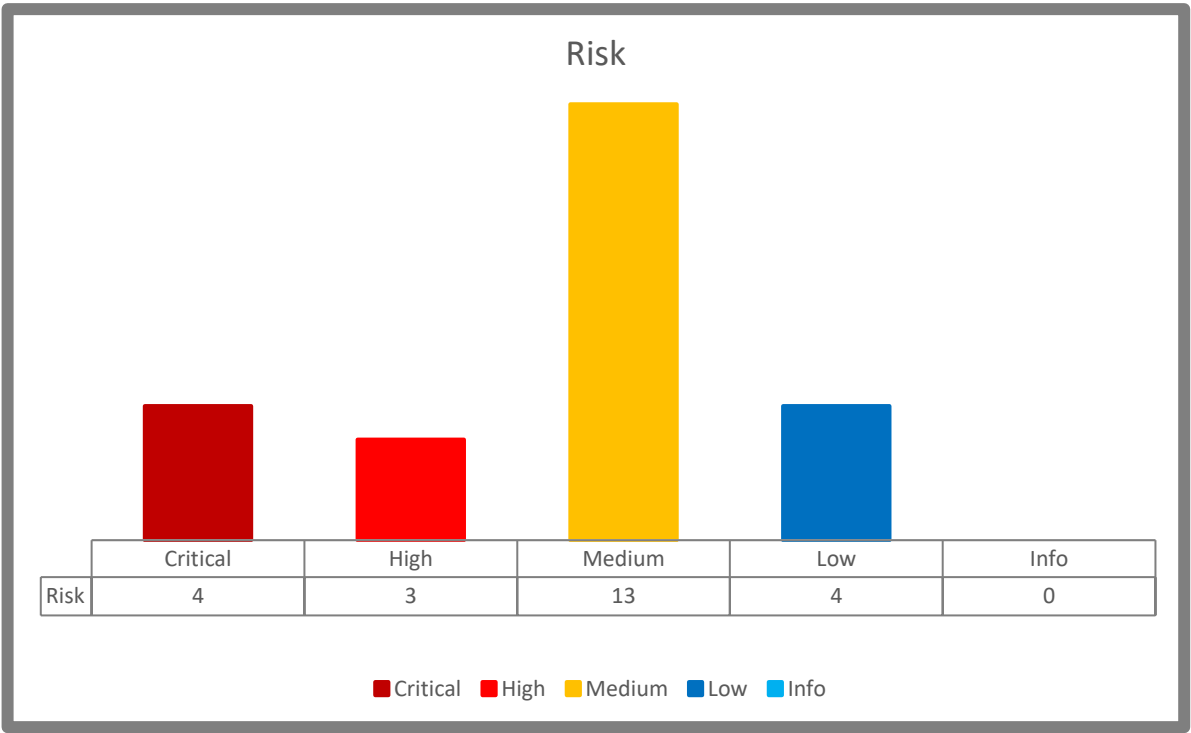
Host: X.X.81.12

```
Starting Nmap 7.97SVN ( https://nmap.org ) at 2025-08-12 16:11 +0530
Nmap scan report for 172.16.81.12
Host is up (0.017s latency).
Not shown: 65529 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
443/tcp    open  https
445/tcp    open  microsoft-ds
5900/tcp   open  vnc
```

## Vulnerability Overview

The Mobile Application Vulnerability Assessment in identification of 04 Critical Risk Vulnerabilities, 03 High Risk Vulnerabilities, 13 Medium Risk Vulnerabilities, 04 Low Risk vulnerabilities and 0 Info Risk vulnerabilities.

## Outcome Summary



Vulnerabilities Table

| Sl. No | Vulnerability Count              | Critical | High | Medium | Low | Info | Total |
|--------|----------------------------------|----------|------|--------|-----|------|-------|
| 1      | Total vulnerabilities Identified | 3        | 2    | 5      | 0   | 0    | 10    |

| Sr. No. | Vulnerability                                             | Risk Rating | CVSS Score | CVE ID         |
|---------|-----------------------------------------------------------|-------------|------------|----------------|
| 1.      | Microsoft SQL Server Unsupported Version Detection        | Critical    | 10.0       | NA             |
| 2.      | Apache Tomcat 9.0.0.M1 < 9.0.104 multiple vulnerabilities | Critical    | 9.8        | CVE-2025-31651 |
| 3.      | Microsoft Message Queuing RCE (QueueJumper)               | Critical    | 9.8        | CVE-2023-21554 |
| 4.      | SSL 64-bit Block Size Cipher Suites Supported (SWEET32)   | High        | 7.5        | CVE-2016-2183  |
| 5.      | Microsoft ASP.NET MS-DOS Device Name DoS                  | High        | 7.5        | CVE-2007-2897  |
| 6.      | SSL Certificate Cannot Be Trusted                         | Medium      | 6.5        | NA             |
| 7.      | SSL Self-Signed Certificate                               | Medium      | 6.5        | NA             |
| 8.      | TLS Version 1.0 Protocol Detection                        | Medium      | 6.5        | NA             |
| 9.      | TLS Version 1.1 Deprecated Protocol                       | Medium      | 6.5        | NA             |
| 10.     | SSL RC4 Cipher Suites Supported (Bar Mitzvah)             | Medium      | 5.9        | CVE-2015-2808  |

# INFRASTRUCTURE VULNERABILITY ASSESSMENT

21

|     |                                                                             |        |     |                                 |
|-----|-----------------------------------------------------------------------------|--------|-----|---------------------------------|
| 11. | SSL Certificate Signed Using Weak Hashing Algorithm                         | Medium | 5.3 | CVE-2004-2761,<br>CVE-2005-4900 |
| 12. | SSL Certificate with Wrong Hostname                                         | Medium | 5.3 | NA                              |
| 13. | SMB Signing not required                                                    | Medium | 5.3 | NA                              |
| 14. | Web Server HTTP Header Information Disclosure                               | Medium | 5.3 | NA                              |
| 15. | Terminal Services Doesn't Use Network Level Authentication (NLA) Only       | Medium | 4.0 | CVE-1999-0517                   |
| 16. | SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)                        | Low    | 3.7 | CVE-2015-4000                   |
| 17. | SSLv3 Padding Oracle on Downgraded Legacy Encryption Vulnerability (POODLE) | Low    | 3.4 | CVE-2014-3566                   |
| 18. | Terminal Services Encryption Level is not FIPS-140 Compliant                | Low    | 2.6 | NA                              |

## 1. Microsoft SQL Server Unsupported Version Detection

Critical

CVSS Score: 10.0

CVSS Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

### Description:

The remote host is running a version of Microsoft SQL Server that is no longer supported by Microsoft — meaning it receives no security updates or patches. Unsupported software is likely to be susceptible to known or future vulnerabilities due to lack of vendor maintenance.

### Solution:

- Inventory & Assess: Document current SQL Server version and support status.
- Upgrade Path: Follow Microsoft's published support lifecycle guidance to determine supported target versions.
- Secure Upgrade: Backup data, upgrade in a controlled window, and ensure rollback mechanisms.
- Verification: upgrade, run scans again to ensure the detection no longer appears.
- Ongoing Maintenance: Implement regular patching and version tracking as part of IT lifecycle management

### Impact:

- No Patches for Vulnerabilities: Unsupported versions may harbor unpatched, exploitable flaws.
- High Exploitability Exposure: As no updates are issued, attackers may target these systems with publicly known exploits.
- Potential Consequences: Unauthorized access, data breaches, loss of integrity, or denial of service—all possible outcomes when attackers exploit available vulnerabilities.

## Attached POC:

| PORT | STATE | SERVICE | VERSION |
|------|-------|---------|---------|
|      |       |         |         |

## Remediation:

- Immediate Action: Upgrade to a currently supported version of Microsoft SQL Server to receive security updates and patches.
- Implementation Steps: Identify clearly which version and service pack is in use.
- Plan for upgrade or migration to a supported release (e.g., SQL Server 2019 or 2022, depending on environment compatibility).
- Perform backups, test the upgrade in a non-production environment, then conduct the upgrade in production with rollback contingencies.
- Re-run vulnerability scans post-upgrade to validate resolution.

## Reference:

- <https://www.tenable.com/plugins/nessus/64784>

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.165      |

## 2. Apache Tomcat vulnerable version in use

Critical

CVSS Score: 9.8

CVSS Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVE ID: CVE-2025-31651

### Description:

Multiple flaws in Tomcat could result in DoS and bypass of security constraints, especially under certain configurations or case-insensitive file systems.

### Solution:

Upgrade to Tomcat 9.0.104 or higher. Conduct controlled upgrade with backups/tests and verify via re-scan.

### Impact:

Potential for service disruption, unauthorized access to protected resources, and compromise of security enforcement.

### Remediation:

- Upgrade Apache Tomcat to version 9.0.104 or later to address all the above vulnerabilities
- For broader coverage (including more recent CVEs affecting up to 9.0.106/9.0.107), consider upgrading further if possible, as per newer advisories
- Deployment steps:
  - Plan and schedule controlled upgrade (backup, test in staging, rollback procedures).
  - Post-upgrade, confirm that the vulnerable version is no longer in use.
  - Re-scan the system to verify resolution of the plugin detection.



## Attached POC:

```
PORT      STATE SERVICE VERSION
8006/tcp  open  http    Microsoft IIS httpd 10.0
```

## Reference:

- <https://lists.apache.org/list.html?announce@tomcat.apache.org>
- <https://www.tenable.com/plugins/nessus/235034>

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.165      |
| X.X.80.214      |

## 3. Microsoft Message Queuing RCE (QueueJumper)

Critical

CVSS Score: 9.8

CVSS Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVE ID: CVE-2014-3566

### Description:

The Queue Jumper vulnerability is a critical remote code execution (RCE) flaw in Microsoft Message Queuing (MSMQ) service. MSMQ is a message queuing service that allows applications running at different times to communicate across heterogeneous networks and systems.

A remote unauthenticated attacker can exploit this vulnerability by sending a specially crafted malicious packet to a vulnerable MSMQ service running on TCP port 1801. Successful exploitation allows the attacker to execute arbitrary code on the target system with SYSTEM-level privileges, potentially leading to full system compromise.

### Solution:

- Apply the official Microsoft Patch for CVE-2023-21554 released in April 2023 Patch Tuesday.
- Ensure Windows Update is enabled and install the latest security updates
- If MSMQ is not required in your environment, disable or uninstall the service to reduce attack surface.

### Impact:

- Remote unauthenticated attackers can take complete control of the system.
- Can be used as an entry point for lateral movement in enterprise networks.
- May lead to data theft, ransomware deployment, persistence mechanisms, and service disruption.
- In cloud and enterprise environments, this vulnerability poses a high risk of widespread exploitation.

### Remediation:

- **Patch Systems:** Immediately apply the latest Microsoft security updates addressing CVE-2023-21554.
- **Disable MSMQ if not in use:**
  - Run services.msc → Locate Message Queuing → Stop and disable the service.

- Alternatively, remove via Windows Features → Uncheck “Message Queuing”.
- **Network Segmentation:** Restrict access to TCP port 1801 using firewalls or access control lists (ACLs).
- **Monitor & Detect:**
  - Enable intrusion detection systems (IDS/IPS) to detect anomalous MSMQ traffic.
  - Monitor event logs for suspicious activity on port 1801.
- Incident Response Readiness: Prepare rollback and response plans in case exploitation is detected.

## Attached POC:

```
[+] 172.16.80.165:1801 - MSMQ vulnerable to CVE-2023-21554 - QueueJumper!
[*] 172.16.80.165:1801 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

## Reference:

- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2023-21554>

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.165      |

## 4. SSL 64-bit Block Size Cipher Suites Supported (SWEET32)

**High****CVSS Score: 7.5****CVSS Vector: 3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N****CVE ID: CVE-2016-2183, CVE-2016-6329**

### Description:

The remote host supports the use of a block cipher with 64-bit blocks in one or more cipher suites. It is, therefore, affected by a vulnerability known as SWEET32, due to the use of weak 64-bit block ciphers. A man-in-the-middle attacker who has sufficient resources can exploit this vulnerability, via a 'birthday' attack, to detect a collision that leaks the XOR between the fixed secret and a known plaintext, allowing the disclosure of the secret text, such as secure HTTPS cookies, and possibly resulting in the hijacking of an authenticated session. The ability to send a large number of requests over the same TLS connection between the client and server is an important requirement for carrying out this attack. If the number of requests allowed for a single connection were limited, this would mitigate the vulnerability.

### Solution:

Reconfigure the affected application, if possible, to avoid use of all 64-bit block ciphers. Alternatively, place limitations on the number of requests that are allowed to be processed over the same TLS connection to mitigate this vulnerability.

### Impact:

An attacker can embed your website within an invisible iframe on a malicious site. Unsuspecting users might then be tricked into performing unintended actions on your site, such as initiating transactions, changing settings, or revealing sensitive information. This not only compromises user trust but can also lead to financial losses and damage to your website's reputation.

### Remediation:

- **Using PowerShell:**
  - Open PowerShell with administrative privileges.
  - Execute the following command to disable the 3DES cipher suite: `Disable-TlsCipherSuite -Name "TLS_RSA_WITH_3DES_EDE_CBC_SHA"`
- **Using Registry Editor:**
  - Press Win + R, type `regedit`, and press Enter to open the Registry Editor.
  - `HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple DES 168` Double-click on "HTTP Response Headers."
  - If the Triple DES 168 key doesn't exist, create it.
  - `[HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple DES 168]`

- Before implementing these changes, ensure that your environment doesn't rely on the disabled ciphers, as this could affect compatibility with older systems or applications. Always back up the registry before making modifications.cryptographic policies.

## Reference:

The SSL 64-bit Block Size Cipher Suites Supported (SWEET32) vulnerability (CVE-2016-6329) allows attackers to exploit weaknesses in 3DES and Blowfish ciphers, enabling plaintext recovery via a collision attack. Mitigation includes disabling weak ciphers and enforcing modern encryption standards like AES-GCM.

- <https://nvd.nist.gov/vuln/detail/CVE-2016-6329>
- <https://sweet32.info/>

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.2        |
| X.X.80.4        |
| X.X.80.5        |
| X.X.80.6        |
| X.X.80.7        |
| X.X.80.8        |
| X.X.80.20       |
| X.X.80.35       |
| X.X.80.165      |
| X.X.80.168      |
| X.X.80.214      |
| X.X.81.12       |

## Attached POC:

```

PORT      STATE SERVICE
3389/tcp  open  ms-wbt-server
| ssl-enum-ciphers:
|   TLSv1.0:
|     ciphers:
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
|     compressors:
|       NULL
|     cipher preference: server
|     warnings:
|       64-bit block cipher 3DES vulnerable to SWEET32 attack
|   TLSv1.1:
|     ciphers:
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
|     compressors:
|       NULL
|     cipher preference: server
|     warnings:
|       64-bit block cipher 3DES vulnerable to SWEET32 attack
|   TLSv1.2:
|     ciphers:
|       TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|       TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (dh 2048) - A
|       TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (dh 2048) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (ecdh_x25519) - A
|       TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp384r1) - A
|       TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A
|       TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA256 (rsa 2048) - A
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
|       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
|     compressors:
|       NULL
|     cipher preference: server
|     warnings:
|       64-bit block cipher 3DES vulnerable to SWEET32 attack
|_  least strength: C
|_  address: 10.10.10.10:3389 (TCP)

```

## 5. Microsoft ASP.NET MS-DOS Device Name DoS

**High****CVSS Score: 9.8****CVSS Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H****CVE ID: CVE-2007-2897****Description:**

A denial-of-service (DoS) vulnerability exists in Microsoft ASP.NET when the framework mishandles MS-DOS device names (e.g., CON, PRN, AUX, NUL) in URL requests.

An unauthenticated remote attacker can exploit this flaw by sending specially crafted HTTP requests containing reserved device names. This causes the ASP.NET application to become unresponsive, leading to service disruption.

The flaw does not allow remote code execution or privilege escalation, but it can be leveraged for downtime attacks on critical applications and portals.

**Solution:**

- Apply Microsoft Security Update MS10-070 that addresses CVE-2010-1899.
- Ensure all ASP.NET framework versions are updated with the latest cumulative patches.
- Validate and sanitize input to reject reserved device names in URLs.

**Impact:**

- Application Denial of Service (DoS): ASP.NET-based applications may crash or hang, making them inaccessible.
- Business Disruption: Prolonged unavailability of web applications/services.
- Exploitation Ease: Attack requires no authentication, making it easy to exploit.
- Can be chained with other vulnerabilities for attack amplification.

**Remediation:**

- **Patch & Update:**
  - Apply Microsoft's security update (MS10-070) across all affected systems.
  - Keep ASP.NET runtime and IIS servers updated regularly.
- **Input Validation:**
  - Implement request filtering in IIS Request Filtering (web.config) to block requests containing reserved device names.

- **Example (web.config rule):**

```
<requestFiltering>
  <denyUrlSequences>
    <add sequence="con" />
    <add sequence="prn" />
    <add sequence="aux" />
    <add sequence="nul" />
  </denyUrlSequences>
</requestFiltering>
```

- **Network Mitigation:**
  - Deploy Web Application Firewall (WAF) to detect and block malicious payloads.
- **Monitoring:**
  - Configure IIS logging to detect abnormal requests targeting CON, PRN, etc.
  - Set up alerts for unusual spikes in request failures.

## Attached POC:

```
/CON
HTTP/1.1 500 Internal Server Error
Server: Microsoft-IIS/10.0
Date: Thu, 14 Aug 2025 12:27:55 GMT
Content-Length: 0
```

```
/AUX
HTTP/1.1 500 Internal Server Error
Server: Microsoft-IIS/10.0
Date: Thu, 14 Aug 2025 12:28:07 GMT
Content-Length: 0
```

```
/PRN
HTTP/1.1 500 Internal Server Error
Server: Microsoft-IIS/10.0
Date: Thu, 14 Aug 2025 12:28:17 GMT
Content-Length: 0
```

Each request to a reserved MS-DOS device name (e.g., CON, AUX, PRN) returned:

HTTP/1.1 500 Internal Server Error



This indicates the server attempted to process the request and failed internally, which aligns with a known denial-of-service condition in Microsoft IIS when handling these special filenames.

**Reference:**

- <https://www.tenable.com/plugins/nessus/64588>

**Affected IP Addresses:**

| Affected Assets |
|-----------------|
| X.X.80.165      |

## 6. SSL Certificate cannot Be Trusted

**Medium****CVSS Score: 6.5****CVSS Vector: 3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N**

### Description:

The detected SSL certificate is issued by an untrusted Certificate Authority (CA), or the certificate may be self-signed. Certificates issued by untrusted CAs are not inherently secure because they cannot validate the authenticity of the server. Consequently, this creates an opportunity for attackers to impersonate the server or intercept sensitive data via a Man-in-the-Middle (MITM) attack.

### Solution:

- **Obtain a Trusted Certificate:**
  - Acquire an SSL certificate from a trusted and recognized Certificate Authority (e.g., DigiCert, GlobalSign, Let's Encrypt).
- **Validate Certificate Chain:**
  - Ensure that all intermediate certificates in the chain are installed and properly configured to allow clients to verify the authenticity of the certificate.
- **Reconfigure SSL/TLS Settings:**
  - Correctly install the newly issued SSL certificate and verify that the server presents the complete certificate chain during the handshake.
- **Implement Certificate Monitoring:**
  - Set up alerts for certificate expiration and periodically review the certificate trust settings.

### Impact:

- **Man-in-the-Middle (MITM) Attacks:**
  - An attacker could intercept and alter communications between the client and server, leading to data leakage, spoofing, or unauthorized access.
- **Loss of Confidentiality and Integrity:**
  - Sensitive data such as login credentials, payment information, or other personal details may be exposed or modified in transit.
- **Trust Issues:**
  - Users accessing the site may receive browser warnings, eroding their trust in the platform or service.
- **Compliance Violations:**
  - Non-compliance with industry standards such as PCI DSS, GDPR, or HIPAA due to insecure SSL/TLS configurations.

## Attached POC:

```
The following certificate was found at the top of the certificate
chain sent by the remote host, but is self-signed and was not
found in the list of known certificate authorities :

|-Subject : CN=SARA-CORP001.SARA.COM
```

## Remediation:

- **Replace the SSL Certificate:**
  - Purchase or generate a certificate from a reputable CA that is recognized by all major web browsers. Free options such as Let's Encrypt can also be used for basic requirements.
- **Configure Certificates Properly:**
  - Install the new certificate along with all required intermediate certificates on the server to create a valid trust chain. Use online tools (e.g., SSL Labs or DigiCert SSL Checker) to verify the setup.
- **Use Strong Encryption Standards:**
  - Ensure that the SSL/TLS configuration supports only strong encryption protocols (e.g., TLS 1.2 or TLS 1.3) and secure ciphers.
- **Monitor Certificate Expiry:**
  - Regularly monitor the SSL certificate expiration dates to avoid the recurrence of similar issues. Automated renewal should be enabled wherever possible.

## Reference:

- <https://www.tenable.com/plugins/nessus/51192>

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.2        |
| X.X.80.4        |
| X.X.80.5        |
| X.X.80.6        |
| X.X.80.7        |
| X.X.80.8        |

|            |
|------------|
| X.X.80.20  |
| X.X.80.35  |
| X.X.80.168 |
| X.X.80.214 |
| X.X.81.12  |

## 7. SSL Self-Signed Certificate

**Medium****CVSS Score: 6.5****CVSS Vector: CVSS: 3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N**

### Description:

The detected SSL certificate is self-signed, meaning it is not issued by a trusted Certificate Authority (CA). Self-signed certificates are inherently untrusted because they lack third-party validation, which ensures that the certificate belongs to the claimed organization or domain. As a result, users accessing the site are likely to encounter browser warnings, which may deter them from proceeding. Additionally, self-signed certificates are susceptible to Man-in-the-Middle (MITM) attacks, as attackers can impersonate the server and intercept sensitive data.

### Solution:

To mitigate this vulnerability, implement the following security measures:

- **Obtain a Trusted Certificate:**
  - Acquire an SSL certificate from a reputable and recognized CA (e.g., DigiCert, GlobalSign, Let's Encrypt).
- **Replace the Self-Signed Certificate:**
  - Install the newly obtained CA-signed certificate on the server and ensure the proper configuration of the certificate chain.
- **Validate Certificate Configuration:**
  - Use tools like SSL Labs or OpenSSL to verify the configuration and trustworthiness of the certificate after replacement.

### Impact:

- **Man-in-the-Middle (MITM) Attacks:**
  - Self-signed certificates allow attackers to impersonate the server, intercept communications, and steal sensitive data such as login credentials or payment information.
- **Loss of Trust:**
  - Browser flag self-signed certificates as untrusted, presenting warnings that can erode user trust and confidence in the platform.
- **Non-Compliance:**
  - Self-signed certificates may violate industry standards and regulations, such as PCI DSS, GDPR, or HIPAA, which require the use of trusted SSL certificates.
- **Security Risks:**
  - Weak authentication undermines the confidentiality and integrity of data exchanged between the server and clients.

## Attached POC:

```
The following certificate was found at the top of the certificate
chain sent by the remote host, but is self-signed and was not
found in the list of known certificate authorities :

|-Subject : CN=SARA-CORP001.SARA.COM
```

## Remediation:

- **Obtain a CA-Issued Certificate:**
  - Purchase or generate a certificate from a trusted CA, such as DigiCert, GlobalSign, or free options like Let's Encrypt for basic needs.
- **Configure and Install the Certificate:**
  - Properly install the CA-issued certificate along with any intermediate certificates to establish a complete chain of trust.
- **Enforce Secure SSL/TLS Settings:**
  - Configure the server to support only secure encryption protocols (e.g., TLS 1.2 or TLS 1.3) and avoid deprecated versions such as SSLv3.
- **Monitor Certificate Expiry:**
  - Set up alerts for certificate expiration and enable automated renewal to avoid reverting to insecure configurations.

## Reference:

- <https://tools.ietf.org/html/rfc5927>
- <https://learn.microsoft.com/en-us/security-updates/>

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.2        |
| X.X.80.4        |
| X.X.80.5        |
| X.X.80.6        |
| X.X.80.7        |
| X.X.80.8        |
| X.X.80.20       |

|            |
|------------|
| X.X.80.35  |
| X.X.80.165 |
| X.X.80.168 |
| X.X.80.214 |
| X.X.81.21  |

## 8. TLS Version 1.0 Protocol Detection

**Medium****CVSS Score: 6.5****CVSS Vector: CVSS: 3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N**

### Description:

The remote service accepts connections using TLS 1.0, an older cryptographic protocol that has known cryptographic vulnerabilities. Although TLS 1.0 was initially widely used, it has been considered insecure due to its design flaws, which include vulnerabilities to attacks like POODLE and issues with cipher suite negotiation. Modern implementations of TLS 1.0 have mitigated some of these problems, but TLS 1.2 and TLS 1.3 are designed to provide stronger security guarantees and should be used to replace TLS 1.0. As a result, keeping TLS 1.0 enabled can expose the server to known vulnerabilities, compromising the security of communications.

### Solution:

- Disable TLS 1.0 in the server configuration and ensure that only TLS 1.2 and TLS 1.3 are enabled.
- Update and Patch: Ensure that your server software and cryptographic libraries are up to date to support TLS 1.2 and TLS 1.3.
- Test After Implementation: After updating your configuration, use SSL/TLS testing tools to ensure that the server only supports secure protocols and cipher suites.

### Impact:

- **Cryptographic Weaknesses:** TLS 1.0 has known vulnerabilities such as susceptibility to man-in-the-middle attacks and cipher block chaining weaknesses.
- **Regulatory Compliance:** Many security standards and regulations (e.g., PCI DSS, HIPAA) require the use of stronger protocols like TLS 1.2 or TLS 1.3. Using TLS 1.0 could result in non-compliance.
- **Data Integrity and Confidentiality:** Using TLS 1.0 exposes communication channels to potential interception, modification, and compromise of sensitive data.

### Remediation:

- **Disable TLS 1.0 in the Server Configuration:**
  - For Apache:
    - Edit the `ssl.conf` or `httpd.conf` file:
    - `SSLProtocol all -SSLv2 -SSLv3 -TLSv1`
    - This disables SSLv2, SSLv3, and TLS 1.0 while enabling TLS 1.2 and TLS 1.3.
  - For Nginx:
    - Edit the `nginx.conf` file:
    - `ssl_protocols TLSv1.2 TLSv1.3;`
    - This explicitly allows only TLS 1.2 and TLS 1.3.
  - **For Java-based servers (e.g., Tomcat):**
    - Edit the `server.xml` configuration file to disable older protocols:
    - `<Connector protocol="org.apache.coyote.http11.Http11NioProtocol"`
    - `sslEnabledProtocols="TLSv1.2,TLSv1.3" />`
- **Restart the Server:**
  - After making the changes, restart the service (e.g., Apache, Nginx, or Tomcat) to apply



the configuration changes.

- **Test the Configuration:**
- Verify that TLS 1.0 has been disabled and that the server supports only the desired versions (TLS 1.2 and TLS 1.3).
- Use tools like SSL Labs' [SSL Test](https://www.ssllabs.com/ssltest/) to check the server's supported protocols.
- You can also use nmap as mentioned earlier to ensure only the stronger protocols are enabled.

## Attached POC:

```
The following certificate was found at the top of the certificate
chain sent by the remote host, but is self-signed and was not
found in the list of known certificate authorities :

|-Subject : CN=SARA-CORP001.SARA.COM
```

## Reference:

- <https://csrc.nist.gov/publications/detail/sp/800-52/rev-2/final>
- [https://cheatsheetseries.owasp.org/cheatsheets/Transport\\_Layer\\_Security\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html)

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.2        |
| X.X.80.4        |
| X.X.80.5        |
| X.X.80.6        |
| X.X.80.7        |
| X.X.80.8        |
| X.X.80.20       |

|            |
|------------|
| X.X.80.35  |
| X.X.80.165 |
| X.X.80.168 |
| X.X.80.214 |
| X.X.81.12  |

## 9. TLS Version 1.1 Deprecated Protocol

**Medium****CVSS Score: 6.5****CVSS Vector: 3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N**

### Description:

The remote service accepts connections using TLS 1.1, a deprecated cryptographic protocol. TLS 1.1 lacks support for modern, recommended cipher suites that provide strong security guarantees, such as authenticated encryption modes like GCM (Galois/Counter Mode). Moreover, TLS 1.1 does not support cipher suites that encrypt data after the Message Authentication Code (MAC) computation, which is considered a modern and more secure encryption approach. This means that connections using TLS 1.1 are more susceptible to cryptographic vulnerabilities like cipher block chaining (CBC) attacks and padding oracle attacks. Since TLS 1.1 is no longer considered secure, its use should be deprecated in favor of more secure versions such as TLS 1.2 or TLS 1.3, both of which provide support for stronger ciphers and better protection against attacks.

### Solution:

- Disable TLS 1.1 in the server configuration and ensure that only TLS 1.2 and TLS 1.3 are enabled.
- Update and Patch: Ensure that your server software and cryptographic libraries are up to date to support TLS 1.2 and TLS 1.3.
- Test After Implementation: After updating your configuration, use SSL/TLS testing tools to ensure that the server only supports secure protocols and cipher suites.

### Impact:

- Cryptographic Weaknesses: TLS 1.1 lacks support for the most current and secure cryptographic ciphers, making it vulnerable to attacks that newer versions mitigate.
- Regulatory Compliance: Many security standards and regulations (e.g., PCI DSS, HIPAA) require the use of TLS 1.2 or TLS 1.3 for secure communication, meaning TLS 1.1 may result in non-compliance.
- Data Integrity and Confidentiality: Using TLS 1.1 increases the risk of attacks such as man-in-the-middle (MitM), data interception, and tampering.

### Remediation:

- Disable TLS 1.1 in the Server Configuration:
- For Apache:
  - Edit the `ssl.conf` or `httpd.conf` file:
  - SSLProtocol all -SSLv2 -SSLv3 -TLSv1 -TLSv1.1
  - This disables TLSv1, TLSv1.1, SSLv2, and SSLv3, leaving only TLS 1.2 and TLS 1.3 enabled.
- For Nginx:
  - Edit the `nginx.conf` file:
  - ssl\_protocols TLSv1.2 TLSv1.3;

- This explicitly allows only TLS 1.2 and TLS 1.3.
- For Java-based servers (e.g., Tomcat):
  - Edit the `server.xml` configuration file to disable older protocols:
  - `<Connector protocol="org.apache.coyote.http11.Http11NioProtocol"`
  - `sslEnabledProtocols="TLSv1.2, TLSv1.3" />`
- Restart the Server:
  - After making the changes, restart the service (e.g., Apache, Nginx, or Tomcat) to apply the configuration changes.
- Test the Configuration:
  - Verify that TLS 1.1 has been disabled and that the server supports only the desired versions (TLS 1.2 and TLS 1.3).
- Use tools like SSL Labs' [SSL Test] (<https://www.ssllabs.com/ssltest/>) to check the server's supported protocols.

## Reference:

- <https://csrc.nist.gov/publications/detail/sp/800-52/rev-2/final>
- [https://cheatsheetseries.owasp.org/cheatsheets/Transport\\_Layer\\_Security\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html)

## Attached POC:

```
The following certificate was found at the top of the certificate
chain sent by the remote host, but is self-signed and was not
found in the list of known certificate authorities :

|-Subject : CN=SARA-CORP001.SARA.COM
```

## Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.2        |
| X.X.80.4        |
| X.X.80.5        |
| X.X.80.6        |
| X.X.80.7        |
| X.X.80.8        |

|            |
|------------|
| X.X.80.20  |
| X.X.80.35  |
| X.X.80.165 |
| X.X.80.168 |
| X.X.80.214 |
| X.X.81.12  |

## 10. SSL RC4 Cipher Suites Supported (Bar Mitzvah)

**Medium****CVSS Score: 7.5****CVSS Vector: 3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N****CVE ID: CVE-2015-2808**

### Description:

The affected system supports RC4-based cipher suites for SSL/TLS communication. RC4 has been deprecated by IETF (RFC 7465) due to serious cryptographic weaknesses.

The Bar Mitzvah Attack exploits predictable biases in the RC4 keystream. By capturing enough encrypted traffic, an attacker can recover sensitive session data (e.g., cookies, authentication tokens, personal information).

Modern cryptographic standards (NIST, PCI-DSS, HIPAA) prohibit the use of RC4 due to these weaknesses.

### Solution:

Reconfigure the affected application, if possible, to avoid use of RC4 ciphers. Consider using TLS 1.2 with AES-GCM suites subject to browser and web server support.

### Impact:

If exploited, this vulnerability may allow an attacker to:

- Decrypt parts of the encrypted traffic (e.g., cookies, tokens, credentials).
- Compromise confidentiality of communications between the client and server.
- Weaken the overall SSL/TLS security posture, making it easier for attackers to perform downgrade or man-in-the-middle (MITM) attacks.

While a direct exploit requires significant traffic capture and computational resources, the risk is considered high for confidentiality.

### Remediation:

Disable RC4 Cipher Suites

- Remove support for all RC4-based ciphers from server configuration.
- Apache:
  - SSLHonorCipherOrder On
  - SSLCipherSuite HIGH:!aNULL:!MD5:!RC4

- Nginx:
  - ssl\_ciphers 'HIGH:!aNULL:!MD5:!RC4';
  - ssl\_prefer\_server\_ciphers on;
- Upgrade to Modern TLS Versions
  - Ensure support for TLS 1.2 and TLS 1.3 with modern cipher suites (AES-GCM, ChaCha20-Poly1305).
- Compliance Alignment
  - PCI-DSS, HIPAA, and NIST guidelines explicitly disallow RC4 usage.

Reference:

- <https://nvd.nist.gov/vuln/detail/CVE-2015-2808>

Affected IP Addresses:

| Affected Assets |
|-----------------|
| X.X.80.165      |
| X.X.81.12       |

Attached POC:

```

ciphers:
  TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
  TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - C
  TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - C

```

## Attacks and Exploits Performed

The following list of potential attacks and exploits has been tested, and the corresponding results are provided.

| Sr. No | Attack or Exploit Details                                                  | Result         |
|--------|----------------------------------------------------------------------------|----------------|
| 1.     | Microsoft Message Queuing RCE (CVE-2023-21554, QueueJumper)                | Vulnerable     |
| 2.     | NFS Shares World Readable Vulnerability                                    | Not Vulnerable |
| 3.     | OpenSSL Heartbeat Information Disclosure (Heartbleed)                      | Not Vulnerable |
| 4.     | SWEET32                                                                    | Vulnerable     |
| 5.     | SSL RC4 Cipher Suites Supported (Bar Mitzvah)                              | Not Vulnerable |
| 6.     | OpenSSL 'ChangeCipherSpec' MiTM Vulnerability                              | Not Vulnerable |
| 7.     | OpenSSH Vulnerable version in use                                          | Not Vulnerable |
| 8.     | Microsoft Windows SMB Shares Unprivileged Access                           | Not Vulnerable |
| 9.     | Remote Desktop Protocol Server Man-in-the-Middle Weakness                  | Not Vulnerable |
| 10.    | Terminal Services Does Not Enforce Network Level Authentication (NLA) Only | Not Vulnerable |
| 11.    | DNS Server Cache Snooping Remote Information Disclosure                    | Not Vulnerable |
| 12.    | Apache HTTP Server Multiple Vulnerabilities                                | Vulnerable     |
| 13.    | POODLE attack                                                              | Not Vulnerable |
| 14.    | Logjam                                                                     | Not Vulnerable |
| 15.    | mDNS Detection (Remote Network)                                            | Not Vulnerable |
| 16.    | Unencrypted Telnet Server                                                  | Not Vulnerable |
| 17.    | MiTM Plaintext Data Injection                                              | Not Vulnerable |
| 18.    | JQuery Vulnerability                                                       | Not Vulnerable |
| 19.    | SNMP Agent Default Community Name (public)                                 | Not Vulnerable |
| 20.    | mssql enum                                                                 | Not Vulnerable |
| 21.    | MS17_010 (Eternal Blue)                                                    | Not Vulnerable |
| 22.    | Microsoft Windows IIS Default Index Page                                   | Not Vulnerable |
| 23.    | Heartbleed (CVE-2014-0160)                                                 | Not Vulnerable |
| 24.    | Oracle Database Server Multiple Vulnerabilities                            | Not Vulnerable |



|     |                                                        |                |
|-----|--------------------------------------------------------|----------------|
| 25. | Ticketbleed (CVE-2016-9244)                            | Not Vulnerable |
| 26. | FREAK (CVE-2015-0204)                                  | Not Vulnerable |
| 27. | DROWN Attack (CVE-2016-0800, CVE-2016-0703)            | Not Vulnerable |
| 28. | BEAST (CVE-2011-3389)                                  | Not Vulnerable |
| 29. | LUCKY13 (CVE-2013-0169)                                | Not Vulnerable |
| 30. | Microsoft ASP.NET MS-DOS Device Name DoS               | Vulnerable     |
| 31. | Buffer Overflow                                        | Not Vulnerable |
| 32. | Microsoft SQL Server Unsupported Version Detection     | Vulnerable     |
| 33. | DNS Server Dynamic Update Record Injection             | Not Vulnerable |
| 34. | SSH Weak Key Exchange Algorithms Enabled               | Not Vulnerable |
| 35. | Multiple BSD ipfw / ip6fw ECE Bit Filtering Evasion    | Not Vulnerable |
| 36. | Microsoft UPnP Local Privilege Elevation Vulnerability | Not Vulnerable |
| 37. | Samba Unsupported Version Detection                    | Not Vulnerable |
| 38. | Samba Badlock Vulnerability                            | Not Vulnerable |
| 39. | NetBIOS Remote Code Execution                          | Not Vulnerable |
| 40. | SSL Self Signed Certificate                            | Vulnerable     |
| 41. | SSH Server CBC Mode Ciphers Enabled                    | Not Vulnerable |
| 42. | SSH Weak MAC Algorithms Enabled                        | Not Vulnerable |
| 43. | SSL Certificate Cannot Be Trusted                      | Vulnerable     |
| 44. | TLS Version 1.0 Protocol Detection                     | Vulnerable     |
| 45. | TLS Version 1.1 Protocol Detection                     | Vulnerable     |
| 46. | TLS Version 1.1 Deprecated Protocol                    | Vulnerable     |
| 47. | ICMP Timestamp Request Remote Date Disclosure          | Not Vulnerable |
| 48. | DNS Server Zone Transfer Information Disclosure        | Not Vulnerable |
| 49. | Oracle/sid_enum                                        | Not Vulnerable |
| 50. | Weblogic Unauthorized bypass RCE                       | Not Vulnerable |
| 51. | Microsoft IIS WebDAV Write Access Code Execution       | Not Vulnerable |
| 52. | MS09-020 IIS6 WebDAV Unicode Authentication Bypass     | Not Vulnerable |
| 53. | ArubaOS-Switch Denial of Service (DoS) Vulnerability   | Not Vulnerable |

# INFRASTRUCTURE VULNERABILITY ASSESSMENT

50

|     |                                                                  |                |
|-----|------------------------------------------------------------------|----------------|
| 54. | Tomcat - Remote Code Execution via JSP Upload Bypass             | Not Vulnerable |
| 55. | Apache Tomcat                                                    | Vulnerable     |
| 56. | SSH Weak Algorithms Supported                                    | Not Vulnerable |
| 57. | SSL Version 2 and 3 Protocol Detection                           | Vulnerable     |
| 58. | SMB DOUBLEPULSAR Remote Code Execution                           | Not Vulnerable |
| 59. | SMB Signing Not Required                                         | Vulnerable     |
| 60. | Linux Multiple statd Packages Remote Format String Vulnerability | Not Vulnerable |
| 61. | IPMI v2.0 Password Hash Disclosure                               | Not Vulnerable |
| 62. | Web Server HTTP Header Information Disclosure                    | Vulnerable     |
| 63. | Web Server Directory Traversal                                   | Not Vulnerable |
| 64. | Oracle WebLogic Unsupported Version Detection                    | Not Vulnerable |
| 65. | Spring4Shell (CVE-2022-22965)                                    | Not Vulnerable |
| 66. | HTTP TRACE / TRACK Methods Allowed                               | Not Vulnerable |
| 67. | IP Forwarding Enabled                                            | Not Vulnerable |
| 68. | Terminal Services Encryption Level is not FIPS-140 Compliant     | Vulnerable     |

## Appendix A – Vulnerability Severity Rating

Vsion Networks rates the impact of individual vulnerabilities as **Critical**, **High**, **Medium**, **Low** & **Info** severity ratings. The scale considers the potential risk of a flaw based on a technical analysis of the exact flaws and its type.

| Level           | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|-----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Critical</b> | Vulnerabilities identified at the Critical Severity level should be investigated immediately. Vulnerabilities at this level assume exploitation of the flaw could lead to full system or data compromise. Examples of critical severity flaws are Command/Code Injection and SQL Injection. Typically, these flaws are rated with CVSS 3.1 between 9.0-10.0.                                                                                                                                                                          |
| <b>High</b>     | Based on the existing controls and information processed, there is a certainty that sensitive information will be susceptible to disclosure, tampering and/or disruption to critical infrastructure. <b>High level vulnerabilities</b> are categorized as the most dangerous, which put a site at maximum risk for hacking and data theft.                                                                                                                                                                                            |
| <b>Medium</b>   | Risk exposure that does not directly compromise the confidentiality, integrity, and/or availability of the areas tested. However, there is a likelihood of intrusion given the current controls, and recommended controls should be implemented to further minimize the risks and constant monitoring should be performed to respond to malicious activities. <b>Medium level vulnerabilities</b> are generally caused by server miss-configuration and site-coding flaws, which facilitate server disruption and directory intrusion |
| <b>Low</b>      | Risk exposure that impacts insignificant business processes/information, or the likelihood of occurrence is negligible. The recommended measures may be implemented to enhance the security posture of the overall infrastructure/processes. <b>Low Level Vulnerabilities</b> are generally caused by server miss-configuration, or directory path disclosures, etc.                                                                                                                                                                  |
| <b>Info</b>     | Info vulnerabilities includes visible information about the network related to the host, such as traceroute information, Internet Service Provider (ISP), or a list of reachable hosts. Intruders may be able to retrieve sensitive information related to the host, such as open UDP and TCP services lists, and detection of firewalls.                                                                                                                                                                                             |